

WEEKLY INTELLIGENCE REPORT

TOP ATTACKS AND BREACHES

- Vercel, a frontend cloud platform, has [disclosed](#) a security incident linked to a compromise at Context.ai, where stolen OAuth tokens enabled unauthorized access through a connected app. The company reported access to employee information, internal logs, and a subset of environment variables, while stating that the most sensitive secrets were not included.
- France Titres, France's authority for identity and registration documents, has [detected](#) a data breach on April 15. The incident may have exposed names, birth dates, email addresses, login IDs, and some physical addresses and phone numbers. A hacker has offered purported agency data for sale on the dark web.
- UK Biobank, a UK research organization, has [confirmed](#) a breach after de-identified health data on 500,000 volunteers was advertised for sale on Chinese marketplaces. Officials said listings were removed and believed unsold, while access was suspended, the research platform was shut down, and download limits were imposed.
- Bitwarden, a popular password manager, has [suffered](#) a supply-chain attack after a malware-tainted CLI release was published to npm on April 22. Bitwarden said 334 developers installed version 2026.4.0 during a brief window, potentially exposing credentials after a hijacked GitHub account was abused, while vault data remained unaffected.

AI THREATS

- Researchers have [flagged](#) unauthorized access to Anthropic's Claude Mythos Preview, an unreleased AI cyber model, through a third-party vendor environment. A small Discord group reportedly used shared contractor accounts, API keys, and predictable URLs to reach the system. Anthropic said it is investigating and has not seen impact to core systems.
- Researchers [observed](#) Bissa Scanner, an AI-assisted exploitation platform using Claude Code and OpenClaw to support mass scanning, exploitation, and credential harvesting. The focus of the operation was exploitation of React2Shell (CVE-2025-55182), while it scanned millions of targets, confirmed over 900 compromises, and collected tens of thousands of exposed environment files.
- Researchers [highlighted](#) a prompt-injection exploit chain in Google's Antigravity agentic IDE that enabled sandbox escape and remote code execution. The flaw abused a file search tool that ran before security checks, letting attackers convert a benign prompt into system compromise, even in Secure Mode. The vulnerability was patched by Google.

VULNERABILITIES AND PATCHES

- Microsoft [issued](#) out-of-band fixes for CVE-2026-40372, a critical ASP.NET Core privilege escalation flaw rated 9.1. A bug in Data Protection versions 10.0.0 to 10.0.6 could let attackers forge cookies and antiforgery tokens, impersonate users, and gain SYSTEM-level access on Linux or macOS deployments.
- Apple [released](#) fixes for CVE-2026-28950 in iOS and iPadOS, a Notification Services bug that retained deleted alerts and allowed recovery of sensitive message previews. The flaw affected many iPhone and iPad models, enabled forensic access with device possession and allegedly allowed law enforcement agencies access to incoming messages from encrypted messaging apps.
- LMDeploy is [affected](#) by CVE-2026-33626, a high-severity server-side request forgery flaw in the open-source toolkit for deploying large language models. Active exploitation began within 13 hours of disclosure, with attackers abusing the image loader to reach cloud metadata, probe internal services, and support lateral movement.
- End of life D-Link DIR-823X routers are [affected](#) by CVE-2025-29635, a remote code execution flaw exploited to deploy a Mirai-based botnet. Akamai reported that attackers are sending requests which fetch and run scripts to conscript devices for denial of service attacks, with no patches expected for the affected models.

Check Point IPS provides protection against this threat (D-Link DIR-823X Command Injection (CVE-2025-29635))

THREAT INTELLIGENCE REPORTS

- Check Point Research has [analyzed](#) The Gentlemen ransomware-as-a-service operation, a group that emerged in 2025 and offers encryptors for Windows, Linux, NAS, BSD, and ESXi systems. The report details its underground recruitment, leak site model, Tox-based negotiations, and SystemBC proxy infrastructure used for persistence and access.
- Researchers [mapped](#) a Mustang Panda espionage campaign targeting India's banking sector and South Korean policy circles, deploying the updated LOTUSLITE backdoor. The group used HDFC-themed help files and fake banking pop-ups, and leveraged DLL sideloading to install the malware.
- Researchers [uncovered](#) a supply-chain attack that inserted credential-stealing malware into Checkmarx developer tools on Docker Hub and Visual Studio Code, including KICS images downloaded over five million times. The malware collects cloud and developer credentials and spreads through stolen GitHub tokens and workflows, with TeamPCP suspected.
- Researchers [tracked](#) a coordinated malvertising campaign abusing Google Ads to impersonate major cryptocurrency platforms like Uniswap, Morpho, and Ledger. The operation uses Google-hosted redirect pages, cloaking, and cloned sites to deploy wallet drainers, seed phrase theft pages, and fake extensions, resulting in at least \$1.27 million stolen.